DoofusAI SPM

AI Security Posture Management

User & Configuration Manual

Author: Shahryar Jahangir
Company: Aniza Corp

Version 3.2 · 2026

Table of Contents

Table of Contents 3

1. Welcome 7

This guide explains how to install, configure, and use DoofusAI SPM. No technical background is needed. 7

1.1 What is DoofusAI SPM? 7

DoofusAI SPM is an AI security scanning tool. If your organisation uses AI chatbots, AI agents, or any software powered by machine learning, this tool finds security weaknesses in those systems before attackers do. 7

It runs automated checks, scores every problem by severity, and shows you a prioritised list of findings with plain-English explanations and step-by-step fix instructions. Every finding is linked to an internationally recognised security standard. 7

DoofusAI SPM was designed and built by Shahryar Jahangir at Aniza Corp. This is version 3.2. 7

1.2 How Many Checks Are There? 7

DoofusAI SPM contains 25 security checks in total, spread across five different types of AI resources. Each check is designed for specific resource types. For example, a check for unsigned model files only makes sense for a model registry, not for a chatbot API. This is intentional and correct. 7

ⓘ The counts above add up to more than 25 because some checks apply

to multiple target types at once (for example, TOOL-DETECT-SECRETS applies to all five types). There are 25 unique checks. The Check Registry screen shows all 25. 8

When you select 'All Checks (Full Scan)', all 25 checks run. Checks that don't natively apply to your selected target type still run — they record their findings against their own native target type for accurate reporting. This gives you complete coverage in a single scan. 8

2. Installation 9

Two options: Docker (easiest, recommended) or Node.js. The start script detects which you have automatically. 9

2.1 Requirements 9

2.2 First-Time Setup 9

2.3 Commands Reference 9

3. Configuration 11

3.1 The .env File 11

The .env file stores your settings and API keys. Open it in any text editor. Lines starting with # are comments and are ignored. A setting looks like: 11

⚠ Never share your .env file. It contains secret API keys. 11

3.2 API Keys 11

Set only the keys for AI providers you actually use. Leave all others blank. 11

ⓘ API keys are read from this file at scan time. They are never stored in the database or shown in the UI. 11

3.3 Optional Scanning Tools 11

These tools add extra scanning capability. All are optional — the app works without them. 11

4. Using the Dashboard 13

Open http://localhost:5173. Navigate using the menu on the left side of the screen. 13

4.1 The Left Menu 13

→ The Findings menu item shows a red badge with the count of open issues. The posture score at the bottom of the menu updates whenever findings change. 13

4.2 Your Security Score 13

The circular dial on the Dashboard shows your posture score from 0 to 100. Every resolved finding improves the score; every new open finding reduces it. The score and all charts update automatically after each scan — no page refresh needed. 13

4.3 Running a Scan — Step by Step 13

Click Scan Config in the left menu. A four-step process guides you through. 13

Step 1 — Choose what to scan 13

Pick the type of AI resource you want to assess. Not sure which to choose? For a chatbot or AI assistant, select LLM / AI API. For an automated

agent, select AI-Integrated App. For your deployment pipeline, select CI/CD Pipeline. 14

Step 2 — Name the target 14

Give the target a name — any label you like, such as "Production chatbot" or "ML training server". Optionally enter its address. If scanning an LLM API, you can also paste in its system prompt. 14

⚠ Never enter API keys into this form. They must be in your .env file.14

Step 3 — Choose check families 14

This is the most important step. Select one or more check families by ticking their checkboxes. You can combine multiple families — for example, tick both OWASP LLM Top 10 and MITRE ATLAS to run both sets together.14

On this screen you will also see an explanation panel that looks like this: 14

This panel explains why "All Checks" runs 25 checks even though only 14 are designed specifically for an LLM API. The other 11 still run — they just record their findings under their own native target type (for example, a CI/CD check will record its finding under cicd_pipeline, not llm_api). This is correct behaviour. 14

→ For daily scans, pick individual families relevant to recent changes. For quarterly assessments, use All Checks (Full Scan). 15

Step 4 — Review and run 15

The individual checks from your selected families are shown with checkboxes. Uncheck any you want to skip. Checks marked with a filled dot (●) are natively designed for your selected target. Checks marked with an open circle (◌) will run cross-target. 15

The banner below the list shows the estimated time. Click Run Checks to start. 15

A progress bar advances check-by-check — typically 0.5 seconds per check. This is intentional so you can see the scan progressing. A 25-check full scan takes about 15–20 seconds. 15

When the scan finishes, a green results banner shows your posture score, findings count, and a View Findings button that takes you directly to the updated Findings page. 15

4.4 Working with Findings 15

Click any row in the Findings table to open a detail panel on the right. It shows the problem description, affected resource, evidence collected, which security standard it maps to, and numbered remediation steps. 15

5. Troubleshooting 16

6. About 17

6.1 Author 17

DoofusAI SPM was designed and built by Shahryar Jahangir at Aniza Corp. © 2026 Aniza Corp. All rights reserved. 17

6.2 Security Frameworks 17

6.3 Version History 17

DoofusAI SPM v3.2 · Shahryar Jahangir · Aniza Corp · 2026 17

1. Welcome

This guide explains how to install, configure, and use DoofusAI SPM. No technical background is needed.

1.1 What is DoofusAI SPM?

DoofusAI SPM is an AI security scanning tool. If your organisation uses AI chatbots, AI agents, or any software powered by machine learning, this tool finds security weaknesses in those systems before attackers do.

It runs automated checks, scores every problem by severity, and shows you a prioritised list of findings with plain-English explanations and step-by-step fix instructions. Every finding is linked to an internationally recognised security standard.

DoofusAI SPM was designed and built by Shahryar Jahangir at Aniza Corp. This is version 3.2.

1.2 How Many Checks Are There?

DoofusAI SPM contains 25 security checks in total, spread across five different types of AI resources. Each check is designed for specific resource types. For example, a check for unsigned model files only makes sense for a model registry, not for a chatbot API. This is intentional and correct.

Target type	Checks that apply	What those checks look for
LLM / AI API	14	Prompt injection, data leakage, API key exposure, rate limits, system prompt security
AI Infrastructure	6	Unauthenticated model platforms, unencrypted storage, pipeline integrity
Model Registry	6	Unsigned model files, missing provenance, supply chain risks
AI Application	15	RAG retrieval safety, agent permissions, vector database isolation, output handling
CI/CD Pipeline	4	Branch protection, secret scanning, model deployment security

ⓘ The counts above add up to more than 25 because some checks apply to multiple target types at once (for example, TOOL-DETECT-SECRETS applies to all five types). There are 25 unique checks. The Check Registry screen shows all 25.

When you select 'All Checks (Full Scan)', all 25 checks run. Checks that don't natively apply to your selected target type still run — they record their findings against their own native target type for accurate reporting. This gives you complete coverage in a single scan.

2. Installation

Two options: Docker (easiest, recommended) or Node.js. The start script detects which you have automatically.

2.1 Requirements

Option	What you need	Best for
Docker	Docker Desktop — free at docker.com	Most people — no technical setup needed
Node.js	Node.js 18 or later — free at nodejs.org	Developers already using Node.js

2.2 First-Time Setup

1. Unzip the package into a folder on your computer.
2. Open Terminal (Mac/Linux) or PowerShell (Windows).
3. Navigate to the folder:

```
cd path/to/doofusai-spm
```

4. Copy the settings file template:

```
cp .env.example .env
```

5. Open .env in a text editor and add any API keys (see Section 3).
6. Start the application:

```
./start.sh
```

After 20–30 seconds you will see:

```
[doofusai] Dashboard  →  http://localhost:5173
[doofusai] API        →  http://localhost:3001
```

7. Open http://localhost:5173 in your browser.

⚠ If Docker gives an error, open Docker Desktop first and wait for it to fully start before running ./start.sh again.

2.3 Commands Reference

Command	What it does
./start.sh	Start the app — auto-detects Docker or Node.js
./start.sh --docker	Force Docker mode

Command	What it does
./start.sh --native	Force Node.js mode
./start.sh --docker --build	Docker mode, rebuild images from scratch
./stop.sh	Stop all DoofusAI SPM processes
./uninstall.sh	Remove the app, keep your scan data
./uninstall.sh --purge	Remove everything including scan data (irreversible)
npm start / npm run stop	Same as ./start.sh and ./stop.sh

3. Configuration

3.1 The .env File

The .env file stores your settings and API keys. Open it in any text editor. Lines starting with # are comments and are ignored. A setting looks like:

```
OPENAI_API_KEY=sk-my-key-here
```

⚠ Never share your .env file. It contains secret API keys.

3.2 API Keys

Set only the keys for AI providers you actually use. Leave all others blank.

Setting	What it enables
OPENAI_API_KEY	OpenAI (ChatGPT, GPT-4)
ANTHROPIC_API_KEY	Anthropic (Claude)
AZURE_OPENAI_API_KEY	Microsoft Azure OpenAI
AWS_ACCESS_KEY_ID / SECRET	Amazon Web Services (SageMaker, S3)
GOOGLE_APPLICATION_CREDENTIALS	Google Cloud (Vertex AI) — path to service account file

ⓘ API keys are read from this file at scan time. They are never stored in the database or shown in the UI.

3.3 Optional Scanning Tools

These tools add extra scanning capability. All are optional — the app works without them.

```
pip install detect-secrets garak llm-guard checkov
```

Tool	What it does
garak	Tests whether an AI model can be tricked into ignoring its safety rules
llm-guard	Detects personal data, harmful content, and injection attacks in AI conversations
checkov	Finds security problems in cloud infrastructure configuration files

4. Using the Dashboard

Open http://localhost:5173. Navigate using the menu on the left side of the screen.

4.1 The Left Menu

Menu item	What it shows
Dashboard	Overall security score, charts, and urgent findings
Findings	Complete list of all security issues — updates immediately after every scan
Scan Config	Run a new security scan
Check Registry	Browse all 25 checks, check for framework updates, view check code
Policy Editor	Write custom security checks for your organisation
Reports	Export scan results
About	App information, author, and security framework details

→ The Findings menu item shows a red badge with the count of open issues. The posture score at the bottom of the menu updates whenever findings change.

4.2 Your Security Score

The circular dial on the Dashboard shows your posture score from 0 to 100. Every resolved finding improves the score; every new open finding reduces it. The score and all charts update automatically after each scan — no page refresh needed.

Score	Label	What to do
90–100	Healthy	No significant issues. Keep monitoring regularly.
70–89	Needs Attention	Some issues present. Plan remediation this week.
40–69	At Risk	Material exposure. Fix critical and high findings now.
0–39	Critical	Severe exposure. Stop and act on critical findings today.

4.3 Running a Scan — Step by Step

Click Scan Config in the left menu. A four-step process guides you through.

Step 1 — Choose what to scan

Pick the type of AI resource you want to assess. Not sure which to choose? For a chatbot or AI assistant, select LLM / AI API. For an automated agent, select AI-Integrated App. For your deployment pipeline, select CI/CD Pipeline.

Step 2 — Name the target

Give the target a name — any label you like, such as "Production chatbot" or "ML training server". Optionally enter its address. If scanning an LLM API, you can also paste in its system prompt.

⚠ Never enter API keys into this form. They must be in your .env file.

Step 3 — Choose check families

This is the most important step. Select one or more check families by ticking their checkboxes. You can combine multiple families — for example, tick both OWASP LLM Top 10 and MITRE ATLAS to run both sets together.

On this screen you will also see an explanation panel that looks like this:

This panel explains why "All Checks" runs 25 checks even though only 14 are designed specifically for an LLM API. The other 11 still run — they just record their findings under their own native target type (for example, a CI/CD check will record its finding under cicd_pipeline, not llm_api). This is correct behaviour.

Family	What it checks
OWASP LLM Top 10	The 10 most critical AI security risks: prompt injection, data leakage, supply chain, poisoning, output handling, and more
MITRE ATLAS	Adversarial AI attack techniques including model extraction, adversarial evasion, and agent context poisoning
AI Infrastructure	MLflow, Jupyter, and model storage security
Model Registries	Model signing, pickle file risk, SBOM completeness
CI/CD Pipelines	Branch protection, action pinning, SLSA levels, drift monitoring
Open-Source Tools	Live scanning using detect-secrets, garak, llm-guard, checkov (requires pip install)
All Checks (Full Scan)	All 25 checks — best for comprehensive first-time assessments

→ For daily scans, pick individual families relevant to recent changes. For quarterly assessments, use All Checks (Full Scan).

Step 4 — Review and run

The individual checks from your selected families are shown with checkboxes. Uncheck any you want to skip. Checks marked with a filled dot (●) are natively designed for your selected target. Checks marked with an open circle (◌) will run cross-target.

The banner below the list shows the estimated time. Click Run Checks to start.

A progress bar advances check-by-check — typically 0.5 seconds per check. This is intentional so you can see the scan progressing. A 25-check full scan takes about 15–20 seconds.

When the scan finishes, a green results banner shows your posture score, findings count, and a View Findings button that takes you directly to the updated Findings page.

4.4 Working with Findings

Click any row in the Findings table to open a detail panel on the right. It shows the problem description, affected resource, evidence collected, which security standard it maps to, and numbered remediation steps.

Button	Effect on the finding
Mark Resolved	Records the fix. Removes the finding from the posture score. Dashboard updates immediately.
Acknowledge	Records awareness without fixing. Finding still counts against the score.
Reopen	Returns a resolved or acknowledged finding back to open status.

5. Troubleshooting

Problem	Solution
Scan shows 14 checks when I selected All Checks	This is expected for an LLM API target — 14 of 25 checks natively apply to that target type. The explanation panel in Step 3 of the wizard explains this. All 25 checks run with All Checks selected; the other 11 record findings under their own native target type.
Recent scans list not updating	The list reads live from application state. Try a page refresh (F5 or Cmd+R) if data looks stale.
Findings page empty after scan	Click View Findings → on the scan result banner. Findings update immediately in root state.
Scan finishes instantly	Scans take 0.4–0.7 seconds per check by design. A 25-check scan takes ~15s. If it completes in under 1 second something is wrong — try stopping and restarting the app.
Docker error on start	Open Docker Desktop, wait for it to fully start, then retry ./start.sh.
Port already in use	Set PORT=3002 in .env and VITE_API_URL=http://localhost:3002, then restart.
Tool check says 'not installed'	Run: pip install detect-secrets garak llm-guard checkov
Reset all scan data	Stop the app, delete the data/ folder, restart.

6. About

6.1 Author

DoofusAI SPM was designed and built by Shahryar Jahangir at Aniza Corp. © 2026 Aniza Corp. All rights reserved.

6.2 Security Frameworks

Framework	Description
OWASP LLM Top 10 (2025)	10 critical AI security risks — all 10 mapped to built-in checks. genai.owasp.org
MITRE ATLAS v5.4.0	84 adversarial ML attack techniques — 3 dedicated checks plus technique IDs on every relevant finding. atlas.mitre.org
NIST AI RMF 1.0	AI risk management framework — every check tagged by function: GOVERN, MAP, MEASURE, MANAGE.

6.3 Version History

Version	Date	Key changes
3.2.0	2026	Fixed: 'All Checks' now runs all 25 checks (not just target-type-filtered subset); clear explanation panel showing check count breakdown; multi-family checkboxes; cross-target check indicators in Step 4
3.1.0	2026	Fixed: recent scans list live update; fixed: Findings page updates after scan; realistic scan progress bar; View Findings button
3.0.0	2026	Left sidebar; About page; stop.sh and uninstall.sh
1.2.x	2026	Docker support; full OWASP LLM Top 10; Check Registry; CI/CD checks
1.0.0	2026	Initial release